

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 28

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM7-108)

Scenario: A coastal hatchery finds altered schedules in automated feeding controls before dawn. The only manager authorized to pause them is traveling without connectivity.

Which delegated-authority provision would BEST prepare the hatchery for this condition?

- A. Require feeding operations to continue until the vice president returns.
- B. Document risk-based suspension authority, limits, alternates, and escalation paths.
- C. Allow every employee to disable all aquaculture systems permanently.
- D. Transfer all feeding-system risk decisions to the equipment supplier.

Question 2 (CISM7-109)

Which change should trigger an out-of-cycle response-plan assessment?

- A. A team changes its weekly meeting agenda.
- B. A dashboard receives a new color palette.
- C. A low-impact office utility receives a routine update.
- D. An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.

Question 3 (CISM7-110)

Scenario: A hospital network and university share a genomics service, but each response plan gives its own incident leader authority to isolate the common platform.

Which governance arrangement BEST resolves the conflicting authority?

- A. A joint response model defining accountable ownership, isolation authority, information flow, and escalation.
- B. Separate command structures that exchange information only after closure.
- C. A rule that the first analyst to see an alert controls both companies.
- D. Automatic public disclosure by either company without coordination.

Question 4 (CISM7-111)

Scenario: A distribution group moved infrastructure and monitoring to new providers, while the response plan still relies on former internal roles and obsolete contacts.

Which plan-maintenance action would MOST improve readiness after outsourcing?

- A. Add more malware indicators to the cyber plan.
- B. Let each plan owner retain incompatible terminology.
- C. Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.
- D. Assign internal audit to lead every operational response.

Question 5 (CISM7-112)

Scenario: A railway marks journey-planning data as critical but omits identity, time synchronization, mapping feeds, and network dependencies from its impact analysis.

Why is the missing dependency information a material readiness weakness?

- A. Recovery sequencing may fail because required supporting services are absent.
- B. The repository hardware may be overinsured.
- C. The incident log may contain too many entries.
- D. Every repository alert will necessarily become a disaster.

Question 6 (CISM7-113)

Scenario: A stadium credentialing service is low impact between events but essential during the hours before a championship match.

How should the stadium reflect this event-driven criticality in preparedness?

- A. Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.
- B. Use only average annual transaction volume.
- C. Rate every credential event at maximum severity all year.
- D. Set priority from the number of servers alone.

Question 7 (CISM7-114)

Scenario: A mortgage lender has approved a recovery-time target but has not determined the acceptable loss of recently submitted applications.

Which additional recovery objective must the lender establish?

- A. A target number of security alerts per day.
- B. A recovery point objective based on acceptable loss of loan-application transactions.
- C. A maximum duration for responder interviews.
- D. A standard attendance level for tabletop exercises.

Question 8 (CISM7-115)

What business outcome should continuity coordination primarily protect?

- A. To transfer investigation ownership to business staff.
- B. To sustain prioritized activity while containment, recovery, and restoration proceed.
- C. To replace containment with manual processing.
- D. To activate alternate sites for every security event.

Question 9 (CISM7-116)

Scenario: A workforce-continuity portal depends on the same endpoint-management platform expected to be isolated during a device-management compromise.

Which design change would make the alternate workspace more resilient?

- A. Delay all continuity activity until the identity service returns.
- B. Accept the design because the workspace is externally hosted.
- C. Increase identity log retention without changing access.
- D. Develop and test an alternate access method that does not depend on the affected mobile-device management service.

Question 10 (CISM7-117)

Scenario: A regional pharmacy can process only one fifth of prescriptions manually, below the approved continuity capacity.

What is the BEST response to the measured manual-processing shortfall?

- A. Approve the process because some results can be recorded.
- B. Lower the minimum without clinical-owner approval.
- C. Redesign and exercise the process to meet the approved requirement or formally address the gap.
- D. Wait for an outage to learn whether the shortfall matters.

Question 11 (CISM7-118)

Scenario: A professional society schedules member applications for recovery before the certificate and directory services they require.

Which recovery ordering decision is MOST appropriate?

- A. Restore the directory and certificate services before applications that depend on it.
- B. Give all components the same recovery point objective.
- C. Recover the most visible application first regardless of prerequisites.
- D. Let each application team choose independently.

Question 12 (CISM7-119)

Scenario: A disaster-recovery test confirms that servers boot but never tests account access, data consistency, payment interfaces, or member transactions.

What must the organization add before calling the recovery test successful?

- A. Only host startup times.
- B. A larger inventory of backup media.
- C. End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.
- D. A review of office furniture at the alternate site.

Question 13 (CISM7-120)

How do RTO and RPO address different recovery requirements?

- A. Both terms describe the maximum length of an investigation.
- B. RTO measures lost data, while RPO measures staff availability.
- C. RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.
- D. Both terms are always identical to supplier service levels.

Question 14 (CISM7-121)

Scenario: A development studio rates incidents by affected endpoints, causing one compromised release-signing key to rank below nuisance software on many kiosks.

Which impact criteria would BEST correct the severity distortion?

- A. Base severity only on hardware replacement cost.
- B. Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.
- C. Let each responder choose a rating without criteria.
- D. Assign maximum severity to every signing-key alert.

Question 15 (CISM7-122)

Scenario: A resort group uses responder judgment alone for escalation, producing inconsistent involvement of legal, safety, franchise, and executives.

Which documented escalation method should replace individual judgment?

- A. Escalation only after financial loss is final.
- B. Escalation whenever any user requests it.
- C. Board escalation for every blocked alert.
- D. Documented thresholds based on impact, data, scope, urgency, safety, and obligations.

Question 16 (CISM7-123)

Scenario: A video platform sends outages, account abuse, content tampering, and privacy incidents to the same team at the same priority.

Which taxonomy change would BEST route these different incident types?

- A. Separate category and severity, then map their combinations to owners, actions, authority, and escalation.
- B. Create one severity for every content title.
- C. Use estimated repair hours as the sole field.
- D. Retain one label and add more email recipients.

Question 17 (CISM7-124)

Scenario: A municipal-utilities exercise reveals no alternate commander, government liaison, or senior briefing owner despite effective technical containment.

What should management do FIRST about the role gaps found in the exercise?

- A. Teach board members to analyze malware.
- B. Map competencies to roles, assign trained personnel and alternates, and retest the gaps.
- C. Ask a contractor to make all corporate decisions.
- D. Remove customs and board injects from later tests.

Question 18 (CISM7-125)

Scenario: A consumer lender repeats the same tabletop script twice a year, and participants now anticipate every inject and decision.

Which exercise-program modification would restore meaningful evaluation?

- A. Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.
- B. Stop documenting results because performance is consistent.
- C. Score only the speed of alert recognition.
- D. Exclude business leaders to shorten the session.

Question 19 (CISM7-126)

Which nondisruptive exercise is MOST suitable for senior leadership?

- A. An unannounced shutdown of live systems.
- B. A routine vulnerability scan.
- C. A facilitated tabletop with progressive business and stakeholder injects.
- D. A count of employees who downloaded the plan.

Question 20 (CISM7-127)

Scenario: An exercise identifies slow supplier escalation, but the report includes no accountable owner, completion evidence, or retest criteria.

What evidence-based follow-up should be required for the exercise findings?

- A. Use attendance as the only success measure.
- B. Delete difficult observations before leadership review.
- C. Create prioritized corrective actions with owners, dates, validation evidence, and retesting.
- D. Approve the plan because the simulation ended.

Question 21 (CISM7-128)

What should an effective triage process establish initially?

- A. A completed root-cause analysis.
- B. An initial determination of incident status, impact, priority, ownership, and routing.
- C. A final external notification package.
- D. A permanent redesign of affected systems.

Question 22 (CISM7-129)

Scenario: A commercial-building operator receives blocked-scan alerts while fire-suppression set points unexpectedly change on one floor.

Which report has the higher immediate assessment priority?

- A. The scans because they contain more events.
- B. The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.
- C. Neither until malicious intent is proven.
- D. Both after the next scheduled meeting.

Question 23 (CISM7-130)

Scenario: Volunteers supporting a relief portal send security concerns to personal contacts, and several credible reports are missed on weekends.

Which reporting arrangement would BEST prevent further missed reports?

- A. Require volunteers to prove compromise before reporting.
- B. Ask coordinators to conduct forensic analysis.
- C. Ignore reports from volunteers below a participation threshold.
- D. Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.

Question 24 (CISM7-131)

Scenario: An automated packing line begins moving robotic arms into staffed areas; an emergency stop may clear short-lived diagnostic memory.

Which action BEST protects people while respecting evidence needs?

- A. Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.
- B. Continue unsafe production until all data is collected.
- C. Erase the controller without recording the action.
- D. Wait for the equipment vendor to decide whether safety matters.

Question 25 (CISM7-132)

Scenario: A senior database specialist whose activity is under review is proposed to collect and interpret all evidence because of unique technical knowledge.

How should investigation leadership be assigned in this case?

- A. Assign independent investigators, control access as authorized, and coordinate with legal and human resources.
- B. Accept a verbal summary from the administrator.
- C. Stop the inquiry unless the administrator agrees.
- D. Publicly name the administrator before validation.

Question 26 (CISM7-133)

Scenario: Warehouse access records are exported to several personal devices without documented source, integrity checks, custodians, or transfers.

Which evidence-management failure creates the GREATEST concern?

- A. The records necessarily identify the wrong employee.
- B. Every recovery objective must be shortened.
- C. The incident automatically becomes a disaster.
- D. Evidence integrity and provenance may be challenged because custody was not maintained.

Question 27 (CISM7-134)

Scenario: A global employer proposes retaining complete customer-service recordings from multiple countries for an insider investigation without first checking local requirements.

What should occur before the recordings are preserved and reviewed?

- A. Collect every recording immediately under one global rule.
- B. Let local supervisors decide legal authority individually.
- C. Notify the suspected individuals publicly.
- D. Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.

Question 28 (CISM7-135)

What is the central management consideration in choosing containment?

- A. The personal preference of the first analyst.
- B. The action used in the previous incident.
- C. The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.
- D. The length of the technical procedure.

Question 29 (CISM7-136)

Scenario: A benefits service confirms misuse of one reseller credential while unrelated resellers are processing time-sensitive enrollments.

Which targeted action BEST contains the active credential abuse?

- A. Delete API logs before isolation.
- B. Leave the key active until service delivery closes.
- C. Disable the entire platform without assessing narrower options.
- D. Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.

Question 30 (CISM7-137)

Scenario: An airport must operate unsupported passenger displays for several more weeks; isolation reduces exposure but makes updates slower.

How should the temporary display restrictions be governed?

- A. Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.
- B. Accept the exposure indefinitely without approval.
- C. Restore unrestricted connectivity to improve speed.
- D. Disconnect every display without considering airport operations.

Question 31 (CISM7-138)

Scenario: A rumor claims a humanitarian foundation published all recipient details, but responders have verified only an application interruption.

Which statement is MOST appropriate while the facts remain limited?

- A. Issue an approved holding statement describing verified impact, response activity, and update channels.
- B. Publish investigators' competing theories.
- C. Remain silent until every corrective action is complete.
- D. Confirm the rumored loss to appear decisive.

Question 32 (CISM7-139)

Scenario: A service provider identifies possible exposure spanning customers with different contracts, regulators, insurers, and locations.

Which notification-assessment step should begin without delay?

- A. A statement that every customer suffered identity theft.
- B. One universal deadline copied from an unrelated rule.
- C. A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.
- D. A delay until final root-cause analysis.

Question 33 (CISM7-140)

Scenario: Executives receive raw telemetry during a cloud-integrity event, while responders receive only a summary of possible brand impact.

How should status reporting be redesigned for these two audiences?

- A. Send identical raw detail to every recipient.
- B. Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.
- C. Allow teams to publish independent estimates.
- D. Stop scheduled updates and answer only questions.

Question 34 (CISM7-141)

Scenario: A cyber event interrupts emergency medicine distribution across several towns during extreme weather, yet crisis leadership remains uninvolved.

Which enterprise coordination step should occur NEXT?

- A. Wait for final technical root cause.
- B. Allow individual analysts to brief the public.
- C. Activate crisis coordination for operational, executive, government, partner, and public communication needs.
- D. Close the incident because pharmacy operators own service delivery.

Question 35 (CISM7-142)

Scenario: A rebuilt cloud service no longer contains the initial malicious component, but unauthorized refresh tokens and a compromised recovery account remain active.

Which eradication activity is required before returning access?

- A. Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.
- B. Restore access and address sessions later.
- C. Close the incident and treat the recovery-account issue as routine support.
- D. Declare eradication complete because the known malicious component is gone.

Question 36 (CISM7-143)

What assurance does recovery validation primarily provide?

- A. To transfer acceptance authority to a vendor.
- B. To prove no future incident can occur.
- C. To remove the need for enhanced monitoring.
- D. To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

Question 37 (CISM7-144)

Scenario: An inventory service is technically available after data tampering, but quantities do not match signed warehouse records.

When should the inventory service return to normal processing?

- A. Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.
- B. Resume inventory processing because infrastructure tests pass.
- C. Let the hosting supplier accept the discrepancy.
- D. Declare success solely because the RTO was reached.

Question 38 (CISM7-145)

Scenario: A marketplace passes recovery checks after account compromise, although the incident team still needs assurance against recurrence.

Which monitoring posture is MOST appropriate during stabilization?

- A. Disable logging to improve performance.
- B. Immediately delete all incident indicators.
- C. Keep the service offline until all enterprise risk disappears.
- D. Restore service gradually with enhanced recurrence monitoring

Question 39 (CISM7-146)

Scenario: An assistant that accepts images disclosed internal instructions after manipulated visual input; response scenarios previously considered text prompts only.

Which lessons-learned package BEST addresses visual-input risk?

- A. Document the event but retain existing assumptions.
- B. Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.
- C. Rely only on employee reminders.
- D. Permanently ban all multimodal service without business analysis.

Question 40 (CISM7-147)

Scenario: Following accidental publication of restricted files, management wants the review centered exclusively on the final approver.

How should the post-incident review be reframed?

- A. Exclude process owners.
- B. Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.
- C. Cancel the review because human error was involved.
- D. Begin by publicly naming the employee.

Question 41 (CISM7-148)

Scenario: Critical backups fail repeatedly because nobody owns the jobs, alerts reach an inactive account, and missed runs are not escalated.

Which issue is the underlying process root cause?

- A. Responders restarted several backup agents.
- B. Business users did not receive recent backup confirmations.
- C. Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.
- D. The service desk received questions about restore readiness.

Question 42 (CISM7-149)

Scenario: Recommendations from a partner-access incident remain unassigned and unverified long after service restoration.

How should management convert the recommendations into verified improvement?

- A. A governed corrective-action register with ownership, priority, dates, validation, escalation, and formal risk acceptance.
- B. Verbal completion claims without evidence.
- C. Automatic closure after a fixed number of months.
- D. Progress review limited to original responders.

Question 43 (CISM7-150)

Scenario: A regional carrier counts incidents and analyst hours but cannot show business impact, response delay, recurrence, recovery, or remediation trends.

Which measures would BEST show whether incident capability is improving?

- A. Only alerts generated per tool.
- B. Only responder labor hours.
- C. Only incidents marked closed.
- D. Impact, response, recurrence, recovery, and remediation trends

Answer Key

Domain IV - Incident Management

1 B	2 D	3 A	4 C	5 A
6 A	7 B	8 B	9 D	10 C
11 A	12 C	13 C	14 B	15 D
16 A	17 B	18 A	19 C	20 C
21 B	22 B	23 D	24 A	25 C
26 D	27 D	28 C	29 D	30 A
31 A	32 C	33 B	34 C	35 A
36 D	37 A	38 D	39 B	40 B
41 C	42 B	43 D		

Detailed Explanations

Question 1 (CISM7-108)

Correct answer: B - Document risk-based suspension authority, limits, alternates, and escalation paths.

In this scenario, bounded delegation enables timely containment while preserving accountability. Waiting permits potential harm, unrestricted authority is excessive, and a vendor cannot assume the cooperative's final risk decision.

Question 2 (CISM7-109)

Correct answer: D - An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.

In this scenario, an acquisition can invalidate scope, ownership, dependencies, contacts, and obligations. Meeting formats, presentation colors, and routine low-impact updates do not materially alter response governance.

Question 3 (CISM7-110)

Correct answer: A - A joint response model defining accountable ownership, isolation authority, information flow, and escalation.

In this scenario, a joint model resolves authority and coordination before an incident occurs. Separate command delays decisions, initial detection does not confer enterprise authority, and uncoordinated disclosure can conflict with verified facts and obligations.

Question 4 (CISM7-111)

Correct answer: C - Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.

In this scenario, common governance and tested interfaces prevent conflicting activation and ownership. More indicators do not resolve coordination, incompatible terms preserve ambiguity, and internal audit should not assume operational command.

Question 5 (CISM7-112)

Correct answer: A - Recovery sequencing may fail because required supporting services are absent.

In this scenario, a critical service cannot be restored effectively without its prerequisites. Log volume and insurance are unrelated, and missing dependencies do not automatically make every alert a disaster.

Question 6 (CISM7-113)

Correct answer: A - Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.

In this scenario, time-sensitive requirements reflect the period of greatest business harm. Annual averages conceal peak exposure, permanent maximum severity wastes resources, and server count is not a business-impact measure.

Question 7 (CISM7-114)

Correct answer: B - A recovery point objective based on acceptable loss of loan-application transactions.

In this scenario, the RPO defines acceptable data loss and complements the time objective. Alert volume, interview duration, and exercise attendance do not establish the permissible rollback of loan-application data.

Question 8 (CISM7-115)

Correct answer: B - To sustain prioritized activity while containment, recovery, and restoration proceed.

In this scenario, continuity sustains essential business activity during disruption while incident teams address the cause and recovery. It does not own investigations, activate for every event, or replace containment decisions.

Question 9 (CISM7-116)

Correct answer: D - Develop and test an alternate access method that does not depend on the affected mobile-device management service.

In this scenario, an effective workaround must avoid the likely failed dependency and be tested. External hosting does not remove device-management reliance, more logs do not restore access, and delay defeats continuity objectives.

Question 10 (CISM7-117)

Correct answer: C - Redesign and exercise the process to meet the approved requirement or formally address the gap.

In this scenario, the known gap should be corrected and tested or explicitly accepted by accountable owners. Partial capacity, an unauthorized requirement change, or waiting for a real incident leaves patient-service risk unmanaged.

Question 11 (CISM7-118)

Correct answer: A - Restore the directory and certificate services before applications that depend on it.

In this scenario, the identity foundation is a prerequisite and must be restored before dependent applications can operate securely. Equal RPOs do not solve order, visibility does not override dependency, and independent sequencing creates conflicts.

Question 12 (CISM7-119)

Correct answer: C - End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.

In this scenario, server startup does not prove business usability. End-to-end testing validates the complete recovered service, while host timing, media inventory, and furniture do not demonstrate operational recovery.

Question 13 (CISM7-120)

Correct answer: C - RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.

In this scenario, rTO concerns how quickly service must return; RPO concerns how much data loss is acceptable. Neither measures staffing or investigation duration, and supplier targets need not equal business objectives.

Question 14 (CISM7-121)

Correct answer: B - Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.

In this scenario, multidimensional criteria capture the potential software-trust impact of one critical signing key. Hardware cost and unstructured judgment are inadequate, while automatic maximum ratings ignore verified context.

Question 15 (CISM7-122)

Correct answer: D - Documented thresholds based on impact, data, scope, urgency, safety, and obligations.

In this scenario, objective thresholds enable consistent, timely routing to appropriate stakeholders. Final loss is too late, user requests alone are insufficient, and board involvement for every alert creates noise.

Question 16 (CISM7-123)

Correct answer: A - Separate category and severity, then map their combinations to owners, actions, authority, and escalation.

In this scenario, category identifies incident nature and severity expresses impact and urgency; mapping both improves routing. Title-level severities are unwieldy, repair time is incomplete, and wider email distribution does not resolve ambiguity.

Question 17 (CISM7-124)

Correct answer: B - Map competencies to roles, assign trained personnel and alternates, and retest the gaps.

In this scenario, role mapping, training, alternates, and retesting address the actual readiness weaknesses. Technical board training, narrower exercises, and outsourced corporate authority do not.

Question 18 (CISM7-125)

Correct answer: A - Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.

In this scenario, varied objective-driven exercises test judgment rather than memory. Removing documentation, relying on one technical metric, or excluding leaders weakens assurance over management response.

Question 19 (CISM7-126)

Correct answer: C - A facilitated tabletop with progressive business and stakeholder injects.

In this scenario, a facilitated tabletop safely tests leadership decisions and cross-functional coordination. A live shutdown creates risk, a scan tests controls, and download counts do not demonstrate capability.

Question 20 (CISM7-127)

Correct answer: C - Create prioritized corrective actions with owners, dates, validation evidence, and retesting.

In this scenario, accountable actions and retesting turn findings into measurable improvement. Suppression, attendance alone, and exercise completion do not show that identified gaps are resolved.

Question 21 (CISM7-128)

Correct answer: B - An initial determination of incident status, impact, priority, ownership, and routing.

In this scenario, triage establishes whether reported activity is an incident and how it should initially be handled. Root cause, notification, and redesign require later facts and authorization.

Question 22 (CISM7-129)

Correct answer: B - The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.

In this scenario, potentially altered fire-suppression settings create immediate occupant-safety risk and outweigh blocked scans. Event volume alone is not impact, and waiting for a meeting or proven intent may allow harm.

Question 23 (CISM7-130)

Correct answer: D - Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.

In this scenario, a monitored channel supports early, consistent reporting and triage. Proof requirements and coordinator investigations delay response, while volunteer role does not determine incident relevance.

Question 24 (CISM7-131)

Correct answer: A - Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.

In this scenario, safety and stabilization take priority, while documentation and feasible evidence collection should continue. Continuing unsafe operation is unacceptable, undocumented erasure harms investigation, and the organization retains safety authority.

Question 25 (CISM7-132)

Correct answer: C - Stop the inquiry unless the administrator agrees.

In this scenario, independent oversight protects evidence and due process while appropriate specialists coordinate personnel and legal issues. Self-investigation creates conflict, consent is not the governing condition, and public attribution is premature.

Question 26 (CISM7-133)

Correct answer: D - Evidence integrity and provenance may be challenged because custody was not maintained.

In this scenario, missing integrity and handling records weaken evidentiary reliability. They do not predetermine attribution, define a disaster, or justify unrelated recovery changes.

Question 27 (CISM7-134)

Correct answer: D - Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.

In this scenario, cross-border collection requires specialist coordination to establish authority, proportionality, handling, and preservation. A universal rule may be unlawful, supervisors are not legal decision makers, and public identification is premature.

Question 28 (CISM7-135)

Correct answer: C - The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.

In this scenario, containment is a risk-based decision balancing harm reduction with operational, evidentiary, safety, authority, and recovery needs. Preference, precedent, and document length alone are insufficient.

Question 29 (CISM7-136)

Correct answer: D - Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.

In this scenario, targeted revocation stops the confirmed path while limiting business impact and preserving evidence. Delay permits harm, full shutdown may be disproportionate, and log deletion impairs investigation.

Question 30 (CISM7-137)

Correct answer: A - Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.

In this scenario, time-bounded compensating measures balance reduced exposure with operations until remediation. Convenience does not justify risk, indefinite acceptance lacks accountability, and wholesale disconnection may create safety issues.

Question 31 (CISM7-138)

Correct answer: A - Issue an approved holding statement describing verified impact, response activity, and update channels.

In this scenario, a factual holding statement addresses stakeholder needs without spreading unsupported claims. Confirming rumors or theories is premature, while prolonged silence can worsen confusion.

Question 32 (CISM7-139)

Correct answer: C - A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.

In this scenario, notification assessment should start promptly using verified facts and applicable obligations. A universal deadline may be wrong, asserted harm may be unsupported, and full root cause is not required to begin analysis.

Question 33 (CISM7-140)

Correct answer: B - Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.

In this scenario, a common verified source maintains consistency while tailored reporting supports each role. Uniform detail creates noise, independent estimates conflict, and purely reactive communication weakens oversight.

Question 34 (CISM7-141)

Correct answer: C - Activate crisis coordination for operational, executive, government, partner, and public communication needs.

In this scenario, widespread essential-service impact requires enterprise crisis coordination while technical response continues. Waiting delays action, individual briefings create inconsistency, and operational ownership does not end the incident.

Question 35 (CISM7-142)

Correct answer: A - Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.

In this scenario, eradication must address all known access paths and enabling weaknesses. Removing one artifact is incomplete, delay preserves unauthorized access, and routine-ticket treatment would close the incident prematurely.

Question 36 (CISM7-143)

Correct answer: D - To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

In this scenario, validation establishes that the service is trustworthy and fit for business use. It cannot prove zero future risk, replace monitoring, or transfer organizational acceptance.

Question 37 (CISM7-144)

Correct answer: A - Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.

In this scenario, availability alone does not prove integrity. Restrictions should remain until validation and business acceptance; suppliers cannot accept organizational risk, and reaching the RTO does not override failed reconciliation.

Question 38 (CISM7-145)

Correct answer: D - Restore service gradually with enhanced recurrence monitoring

In this scenario, controlled return with enhanced monitoring provides assurance during stabilization. Disabling visibility or deleting indicators is premature, while waiting for elimination of all risk is impractical.

Question 39 (CISM7-146)

Correct answer: B - Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.

In this scenario, the review should update risk assumptions, safeguards, procedures, training, and exercises based on observed behavior. No change or reminders alone are incomplete, while a blanket ban may be disproportionate.

Question 40 (CISM7-147)

Correct answer: B - Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.

In this scenario, a systemic review identifies sustainable improvements and supports candor. Excluding owners, public blame, or cancellation leaves organizational weaknesses unresolved.

Question 41 (CISM7-148)

Correct answer: C - Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.

In this scenario, the failed ownership, monitoring, and escalation process explains the recurring backup failures. Missing confirmations and questions are symptoms, while restarting agents is a response action rather than the systemic root cause.

Question 42 (CISM7-149)

Correct answer: B - Verbal completion claims without evidence.

In this scenario, a governed register turns lessons into accountable and verifiable improvement and exposes residual-risk decisions. Time, unsupported claims, and narrow review do not demonstrate completion.

Question 43 (CISM7-150)

Correct answer: D - Impact, response, recurrence, recovery, and remediation trends

In this scenario, balanced measures connect operations to business consequence, timeliness, repeated causes, recovery, and improvement. Alert, labor, or closure counts alone can hide deteriorating risk.